

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE:CSA5115 COURSE NAME: Cryptography and Network Security
SLOT:A

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I Nissanki Sri Venkata Lakshmi kavya (192373036) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

N.S.V.L.Kavya

Annexure A
Industry Problem-Solving Task

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

Secure Email Communication: PGP vs S/MIME

1. Comparison of PGP and S/MIME

Feature	PGP	S/MIME
Main purpose	Email encryption and digital signatures	Email encryption and digital signatures
Trust model	Web of Trust	Certificate Authority (CA) based
Key management	Users manage their own keys	Certificates are issued and managed by CAs
Usability	More complex for ordinary users	Easier for enterprise users

Scalability	More difficult to manage in large organizations	Highly scalable
Enterprise integration	Requires additional configuration and tools	Strong integration with enterprise email systems
Certificate management	User-controlled	Centralized through PKI
Best suited for	Individuals, technical users, open communities	Businesses, governments, financial organizations

2. Key Management and Trust Models

PGP

PGP commonly uses a **Web of Trust** model. Users create their own public/private key pairs and can digitally sign other users' public keys to indicate that they trust them. This gives users more control but can make key management complicated in a large organization.

S/MIME

S/MIME uses a **Public Key Infrastructure (PKI)**. A trusted **Certificate Authority (CA)** issues digital certificates that associate a user's identity with their public key. The organization can centrally manage certificate issuance, renewal, revocation, and policies.

For a financial organization, centralized certificate management provides better administrative control and makes it easier to enforce security policies.

3. Recommendation

For the financial services company, **S/MIME is recommended.**

The main reasons are:

1. **Better usability** – S/MIME can be integrated into commonly used enterprise email clients.

2. **Scalability** – Certificates can be centrally managed for a large number of employees.
3. **Enterprise integration** – S/MIME works well with enterprise email and directory systems.
4. **Centralized trust** – The organization can use a trusted CA and establish clear certificate policies.
5. **Strong security** – It provides encryption, authentication, message integrity, and digital signatures.
6. **Compliance and administration** – Centralized certificate management makes it easier to maintain organizational security policies and audit requirements.

PGP can still be appropriate for specialized users or situations where decentralized key ownership is preferred, but S/MIME is generally more practical for a large financial enterprise.

4. High-Level Implementation Workflow

The implementation can follow these steps:

Step 1: Establish PKI

Set up or select a trusted Certificate Authority (CA) for issuing S/MIME certificates.

Step 2: Generate key pairs

Each employee receives a public/private key pair. The private key is securely stored and protected.

Step 3: Issue certificates

The CA verifies the employee's identity and issues an S/MIME digital certificate containing the employee's public key.

Step 4: Configure email clients

Configure the organization's email clients and servers to support S/MIME encryption and digital signatures.

Step 5: Send a signed email

The sender digitally signs the email using their private key. The recipient uses the sender's public key to verify the signature.

Step 6: Encrypt sensitive emails

The sender encrypts the email using the recipient's public key. Only the recipient's private key can decrypt it.

Step 7: Certificate lifecycle management

The organization regularly renews certificates and revokes certificates if a private key is compromised or an employee leaves the organization.

Workflow

Employee → Key Pair → CA Verification → S/MIME Certificate → Email Client → Digital Signature / Encryption → Secure Email → Recipient → Certificate Verification → Decryption

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators
- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

Advanced Spam and Phishing Detection Strategy

Introduction

The company's existing email system is experiencing an increase in phishing and spam attacks even though basic filtering mechanisms are already being used. Basic filters that depend mainly on keywords, sender addresses, or simple blacklists may fail to identify modern phishing emails because attackers can change their content, spoof sender information, and use newly created domains. An advanced detection system should

analyze both **email headers and email content** to identify suspicious messages more accurately.

1. Limitations of Existing Filtering Techniques

Basic email filtering has several limitations:

- **Keyword-based filtering:** Attackers can change words or use images instead of text to avoid detection.
- **Blacklist-based filtering:** New malicious domains and email addresses may not yet be present on the blacklist.
- **Sender-address filtering:** Attackers can spoof or imitate trusted sender addresses.
- **Static rules:** Fixed rules cannot easily adapt to new phishing techniques.
- **High false positives:** Legitimate emails may be incorrectly classified as spam.
- **Limited content analysis:** Basic filters may not examine links, attachments, writing patterns, or the overall context of the message.

Therefore, the company needs a detection system that combines multiple indicators rather than depending on a single filtering technique.

2. Email Header Analysis for Spoofing Indicators

Email headers contain important information that can help identify suspicious messages.

Important Header Indicators

From:

Checks the displayed sender address. A phishing email may use an address that looks similar to a legitimate company address.

Return-Path:

Shows where bounced messages are sent. A mismatch between the Return-Path and From address can be suspicious.

Received:

Shows the servers through which the email travelled. Unexpected or suspicious originating servers can indicate phishing.

Reply-To:

If the Reply-To address is different from the sender address, it may indicate an attempt to redirect the recipient's response.

SPF:

Checks whether the sending server is authorized to send email for the domain.

DKIM:

Uses a digital signature to verify that the email was authorized by the domain and was not modified during transmission.

DMARC:

Uses domain authentication results from SPF and DKIM and applies a policy for handling messages that fail authentication.

Example

If an email claims to come from:

bank.example.com

but the authentication results show that:

- SPF = Fail
- DKIM = Fail
- DMARC = Fail
- Return-Path = unrelated-domain.com

the email should receive a high risk score because several spoofing indicators are present.

3. Improved Detection Model

A hybrid rule-based and machine-learning model is recommended.

Step 1: Collect Email Data

Collect:

- Email headers
- Sender and recipient information
- Subject
- Message body
- URLs
- Attachments
- Authentication results

Step 2: Extract Features

The system extracts features such as:

- SPF/DKIM/DMARC results
- Sender-domain reputation
- Difference between From and Reply-To
- Number of URLs
- Suspicious URLs or domains
- Presence of attachments
- Urgency-related words
- Requests for passwords or financial information
- HTML characteristics
- Sender history

Step 4: Machine Learning

A machine-learning classifier can be trained using previously labelled emails:

- **Spam**
- **Phishing**
- **Legitimate**

Algorithms such as **Random Forest, Logistic Regression, or Support Vector Machine (SVM)** can be used.

The model learns patterns from email headers, text, URLs, and other features and produces a probability or risk score.

Step 5: Final Decision

The rule-based score and ML prediction can be combined:

Email → Header Analysis + Content Analysis → Rule Engine + ML Model → Risk Score → Final Classification

The email can then be placed into:

- **Safe/Inbox**
- **Suspicious/Quarantine**
- **High-risk/Blocked**

4. Effectiveness and False Positive Handling

The system should be evaluated using:

- **Accuracy:** Overall percentage of correctly classified emails.
- **Precision:** Percentage of emails classified as spam that are actually spam.
- **Recall:** Percentage of actual spam/phishing emails detected.
- **F1-score:** Balance between precision and recall.

- **False Positive Rate:** Percentage of legitimate emails incorrectly classified as spam.

For a business environment, reducing false positives is especially important because legitimate financial or customer emails must not be blocked unnecessarily.

False Positive Handling

To reduce false positives:

1. Use a **quarantine folder** instead of immediately deleting suspicious emails.
2. Allow users to mark messages as **Not Spam**.
3. Add trusted business domains and senders to an allowlist.
4. Continuously retrain the ML model using newly labelled emails.
5. Use different risk thresholds for different categories of users.
6. Keep logs of detection decisions for security analysis.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts

		solve the problem			
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation